

Controls Assessment Checklist

To complete the controls assessment checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each control, including the type and purpose, refer to the control categories document.

YES	NO	CONTROL
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☐	☒	Firewall
☐	☒	Intrusion detection system (IDS)
☒	☐	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance Checklist

To complete the compliance checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each compliance regulation, review the controls, frameworks, and compliance reading.

Payment Card Industry Data Security Standard (PCI DSS)

YES	NO	BEST PRACTICE
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☒	☐	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

YES	NO	BEST PRACTICE
☐	☒	E.U. customers' data is kept private/secured.
☐	☒	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

YES	NO	BEST PRACTICE
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

Executive Summary & Recommendations

Overview: A comprehensive security controls and compliance assessment was conducted for Botium Toys to evaluate the organization's current security posture, identify structural vulnerabilities, and ensure alignment with key regulatory frameworks (PCI DSS, GDPR, and SOC). The assessment revealed critical gaps in core technical defenses, identity management, and data privacy controls that expose the organization to significant operational, financial, and legal risks.

Key Findings & Security Gaps

- **Lack of Perimeter and Network Defenses:** Botium Toys currently does not have a Firewall or an Intrusion Detection System (IDS) implemented. This lack of network architecture control leaves the internal asset environment highly vulnerable to external threat actors and unauthorized lateral movement.
- **Weak Access and Identity Management:** While basic password policies are in place, the organization lacks a centralized Password Management System and fails to enforce Separation of Duties or the principle of Least Privilege. Furthermore, user access policies are not formally established, increasing the risk of insider threats and credential misuse.
- **Compliance Violations (PCI DSS & GDPR):**
 - **PCI DSS:** The organization currently fails to restrict credit card data access to authorized users, lacks encryption across transaction touchpoints, and does not maintain a secure transmission environment.
 - **GDPR:** There is currently no incident response plan to notify E.U. customers within 72 hours of a data breach, and data is not properly classified or inventoried.

Strategic Recommendations

To mitigate these identified risks and establish a robust security baseline, the following technical and administrative controls must be implemented immediately:

Priority 1: Deploy Core Network Protections (Technical Controls)

Immediately implement a hardware/software Firewall to filter inbound and outbound traffic and deploy an Intrusion Detection System (IDS) to monitor for malicious network activity and potential breaches.

Priority 2: Secure Customer Data and Achieve Regulatory Compliance (Compliance & Data Security)

Remediate PCI DSS Gaps: Enforce strict access control mechanisms to ensure only authorized personnel can access customer financial data. Deploy end-to-end data encryption protocols across all credit card transaction touchpoints and storage environments.

Remediate GDPR Gaps: Develop and document an Incident Response Plan (IRP) that outlines specific procedures for detecting, containing, and reporting a data breach, ensuring the capability to notify E.U. customers within the mandatory 72-hour window. Conduct a comprehensive data discovery project to classify and inventory all consumer data.

Priority 3: Strengthen Identity & Access Management (Administrative Controls)

Formalize and enforce User Access Policies based on the principle of least privilege.

Mandate the use of a corporate Password Management System.

Restructure internal roles to enforce Separation of Duties, ensuring that no single user has total control over critical financial or administrative system processes.